

CITINEL — App Fact Sheet

Autonomous glass-box AI Cyber SOC for Indian cooperative banks · CITE + SENTINEL · caught, cited, gated, actioned, closed

Decode SIH 2026 · Track 3 Bharat Pragati · PS4 “Autonomous Cyber SOC” · live: citinel-web.onrender.com · generated 2026-09-05

What it is

An autonomous SOC where Claude-powered agents investigate every alert with **cited evidence**, act only inside a **per-action policy a human can read**, and draft India’s mandatory **CERT-In 6-hour** report and **DPDP** breach artifacts the moment an incident is confirmed. The gap it closes: SIEMs know what happened but don’t write the regulator’s form; compliance tools write forms but don’t know what happened. In CITINEL the investigation itself writes the draft — detection to regulator-ready report, one pipeline.

Why now (the problem)

- 2024: one ransomware attack took ~300 Indian cooperative banks offline.
- RBI requires a 24x7 SOC; a human one costs INR 1-2 crore/yr against budgets of INR 25k-1L/month.
- India’s average breach cost is a record INR 220M (IBM, 2025).
- A CERT-In 6-hour clock and DPDP’s stackable INR 250cr + 200cr penalties tick over every incident.

What it does (four capabilities)

Capability	In one line
Glass-box cited triage	Sigma rules catch known threats deterministically; Claude agents correlate the rest into a MITRE ATT&CK kill-chain where every verdict cites the exact log line proving it.
Readable autonomy dial	Per-action-class OPA policy: enrichment auto, isolation with rollback, consequential actions wait for one-click human approval. Shadow -> Assist -> Autonomous, with blast-radius caps.
Injection-hardened pipeline	All log content is quarantined as untrusted data; a poisoned log cannot hijack the AI. Inter-agent laundering is fenced before the narrator sees it.
Compliance clock	On confirmation, CERT-In 6-hour and DPDP breach drafts are generated from the live incident record for human sign-off. We draft; we never file.

What it is built on (tech stack)

Layer	Built with
Backend	Python 3.11, FastAPI, uvicorn; pydantic-settings config; served as one ASGI app.
Detection	OCSF normalizer, Sigma engine (pysigma), statistical anomaly scoring — deterministic, no model, no key.
Reasoning	Anthropic Claude agent swarm; OPA-style readable policy gate; egress allow-list.
Console	Hand-written “DC runtime” HTML, 18 screens; shared api.js (backend seam), nav.js (rail), a11y.css.
Audit	SHA-256 hash-chained append-only ledger; independent Lyzr witness.
Deploy	Render (Docker), branch build/stage-1; persistent disk for ledger + artifacts. 420 tests passing.

What data it uses (license-clean, simulation-only)

Dataset / source	Role	License
Splunk BOTS v1 (Boss of the SOC)	Telemetry replay corpus — the real data behind every demo incident (128 MB attack-only slice).	CC0
Sigma rules r2026-07-01	Deterministic detection rulebook — 3,302 rules; 29 fired on this corpus.	DRL/OSS
MITRE ATT&CK v16.1	Technique tagging — 29 techniques observed in this run.	Open
Atomic Red Team	Attack-vs-defense demo, run in an isolated VM.	MIT

Not used: no “meteor” or other dataset. Response actions hit mocked endpoints; no production system is ever touched.

Architecture (one pipeline)

Telemetry (syslog / webhook · BOTS replay) → OCSF normalizer → Sigma engine + anomaly scoring → agent swarm → OPA policy gate + autonomy dial → simulated response endpoints → append-only hash-chained ledger → compliance drafter → glass-box console.

The agent swarm (seven roles)

Sentinel (orchestrator) · Triage Router · Enrichment Squad · Correlator · Verdict Narrator · Response Marshal · Scribe.

Models (verified live against /v1/models): **claude-haiku-4-5-20251001** for triage, **claude-sonnet-5** for reasoning. One real run on INC-0417: ~114K input / 31K output tokens, 6 claims cited, 0 dropped, confidence 0.66-0.72.

External integrations (11, each wired and proven by a real call)

Service	What it does in CITINEL
Anthropic	The agent swarm (triage + reasoning).
Tavily	Regulatory / threat context (search, extract, map, crawl, research).
Gemini	Long-context blind-spot sweep + analyst-image read; carries not_evidence.
Lyzr (7 agents)	Triage, review, handover, verdict, response, corpus, and the ledger witness.
n8n	Post-sign-off automation (notify CISO, ticket) + REST read-back plane.
Swytchcode	Policy-gated runtime transport to GitHub and Slack via the swy CLI.
Startuped	Aggregate-count signals only; refuses any field carrying incident content.
AbuseIPDB / VirusTotal	IP and file reputation enrichment (deterministic egress allow-list).
Slack / GitHub	Notification and ticketing legs, reached through the policy-gated CLI.

16 of 16 connectors configured on the live deployment. Egress: six hosts on a static exact-host https allow-list; Lyzr and n8n pinned to their configured host; three reached through a policy-gated CLI.

Compliance output

- **CERT-In 6-hour incident report** (cl. 12, Cyber Security Directions 2022): 8 of 10 fields machine-drafted, 2 auto-suggested for human confirmation, 0 human-only left blank — 80-100% coverage from the record alone.
- **DPDP breach report** (Rule 7): prepared under a separate statute and trigger, so nothing is written from scratch later.
- No CERT-In API exists; submission is the bank's act by email/phone/fax. CITINEL holds no portal credential and files nothing.

What a judge can check (differentiators)

- Citation-verified verdicts: a claim whose quote is absent from the cited finding is dropped, not flagged.
- Observation vs fact enforced in the payload: model output carries not_evidence; corroboration is deterministic with citable indices.
- Hash-chained ledger with an independent witness that catches wholesale replacement a local verify cannot.
- Blind-spot disclosure then closure: 40 of 2,487 findings examined by the swarm, said out loud, then swept.
- Fail-closed writes with distinguishable failures (503 unset vs 401 wrong); no measurement without its denominator.

Policy, ledger, deployment

Area	Facts
Policy & autonomy	Readable policy v1 (sha256 57c3bbbbaa69b...). Per action class: 1 shadow, 4 assist, 3 autonomous. Rollback tokens; blast-radius caps.
Ledger & witness	SHA-256 hash-chained, append-only (~5,800 entries). Lyzr witness reports lagging/diverged honestly.

Area	Facts
Deployment	Render Docker: citinel-web, citinel-pipeline (worker), citinel-ledger-watch (cron), citinel-n8n; persistent disk.
Environment	40 env vars total; 28 external across 9 third-party services; secrets hand-set in Render.
Console	18 screens; device-arming write model (named operator token, 12h); ANALYST/CISO depth; read-open, write-gated.

Key numbers (each with its denominator)

Metric	Value
Demo incidents	3 — INC-0416 (337 findings), INC-0417 (2,487), INC-0419 (2,487, live-clock hero)
Sigma corpus	3,302 rules (r2026-07-01); 29 distinct fired
ATT&CK techniques observed	29 of 823 enterprise techniques (this corpus run; not a coverage claim)
Connectors configured	16 of 16 on the live deployment
Build steps / tests	15 of 15 built; 420 tests passing

Honest limitations (stated, not hidden)

- **False-positive rate is UNMEASURED** — no labeled ground-truth corpus exists. The under-10% figure is a target, never a measured result.
- Sign-offs are drafts. We draft, we never file.
- Response actions hit simulated endpoints only.
- No per-user authentication yet: a shared operator token gates writes; the ANALYST/CISO toggle is view depth, not access control.
- No prize is guaranteed. Nothing a model says is evidence; only deterministic corroboration with citable indices is.

CITINEL drafts regulator reports; humans review and file them. Data is Splunk BOTS v1 (CC0) replay. Detection targets and false-positive rates are measured on labeled datasets and reported as ranges — never claimed.